



Transformación Digital

Agencia de Transformación Digital y Telecomunicaciones

Dirección General de Ciberseguridad

REFERENCIAS DIRECTAS A OBJETOS INSEGUROS (IDOR)

Febrero 2026



TLP:AMBER+STRICT

Restringe el acceso y la difusión de información exclusivamente a los miembros de la organización receptora

Consideraciones generales

Derivado de actividades de supervisión y revisiones técnicas realizadas por la Agencia de Transformación Digital y Telecomunicaciones, por conducto de la Dirección General de Ciberseguridad, se ha identificado de manera recurrente la vulnerabilidad **Insecure Direct Object Reference (IDOR)** en sistemas, aplicaciones y APIs institucionales.

De conformidad con el OWASP Top 10 – edición vigente, esta vulnerabilidad se encuentra clasificada dentro de la categoría:

1. **A01: Broken Access Control**

Asimismo, en el contexto de APIs, dicha debilidad corresponde a:

- **OWASP API Security Top 10 – API1: Broken Object Level Authorization (BOLA)**

OWASP establece que *Broken Access Control* continúa siendo la categoría de mayor prevalencia e impacto, manteniéndose como riesgo crítico en los ciclos de actualización y adopción vigentes al año 2025.

Descripción de la vulnerabilidad conforme a OWASP

La vulnerabilidad **Insecure Direct Object Reference (IDOR)** se presenta cuando una aplicación expone referencias directas a objetos internos mediante identificadores controlados o manipulables por el cliente y **no implementa validaciones adecuadas de autorización a nivel de objeto en el backend**.

Este escenario ocurre típicamente cuando:

1. El sistema valida que la persona usuaria esté autenticada.
2. **No valida que dicha persona esté autorizada para acceder al recurso específico solicitado.**

OWASP identifica este patrón como una **confusión entre autenticación y autorización**, lo cual constituye un incumplimiento directo a los principios de control de acceso seguro.

Para mayor referencia, se muestra dos ejemplos ilustrativo:

Un usuario autenticado accede correctamente a su recurso:

[GET /api/documentos?id=45821](#)

Posteriormente modifica el identificador:

[GET /api/documentos?id=45822](#)



// URL normal

<https://ejemplo.com/user/profile?id=1234>

// Ataque IDOR: cambiar el ID para acceder al perfil de otro usuario

<https://ejemplo.com/user/profile?id=5678>

Si ambos sistemas devuelven información de otro usuario:

- **No se rompió la autenticación.**
- **Se manipuló un identificador expuesto.**
- **Falló el control de acceso a nivel de objeto.**

Recursos potencialmente afectados

IDOR puede impactar cualquier recurso cuya referencia dependa de identificadores proporcionados por el cliente y que no cuente con validaciones de autorización a nivel de objeto en el backend, incluyendo:

1. Cuentas, perfiles o registros de usuario
2. Expedientes, historiales, trámites y solicitudes
3. Documentos, archivos y evidencias digitales
4. Configuraciones y parámetros del sistema

La vulnerabilidad puede manifestarse en:

- Aplicaciones web
- Aplicaciones móviles
- APIs REST y GraphQL
- Microservicios y servicios backend

Identificadores explotables (OWASP)

OWASP documenta que los atacantes suelen manipular:

1. IDs numéricos (**id=123**)
2. UUID / GUID
3. Folios o números de expediente
4. Datos personales (CURP, RFC, correo electrónico)
5. Hashes u otros identificadores ofuscados
6. Identificadores en headers, body o tokens
7. Rutas directas a archivos

El uso de UUID, hashes u ofuscación no mitiga IDOR si no existe una validación explícita de autorización a nivel de objeto.



Riesgo asociado

Broken Access Control es un riesgo crítico que ha derivado en:

1. Acceso no autorizado a información sensible o datos personales.
2. Exposición masiva o extracción de información institucional.
3. Modificación o eliminación de información de terceros.
4. Escalamiento horizontal de privilegios.
5. Afectaciones graves a la confidencialidad, integridad y disponibilidad.

Indicadores comunes de exposición

Los sistemas con riesgo de IDOR suelen presentar uno o más de los siguientes anti-patrones:

- **Exponen identificadores directos:** uso de parámetros como `id`, `user_id`, `account_id`, `document_id`, etc. sin validación de pertenencia al usuario autenticado.
- **Validación basada únicamente en autenticación:** el sistema verifica que el usuario inició sesión, pero no valida si tiene permiso para acceder a ese recurso específico.
- **Controles de acceso dispersos o inconsistentes:** algunas rutas validan permisos y otras no, o versiones antiguas de una API aplican menos controles.
- **Patrones de acceso repetitivo a múltiples recursos:** una misma identidad accediendo a numerosos registros distintos en un periodo corto, sin restricciones visibles.

Aunado a lo anterior, considerando que las dependencias y entidades de la Administración Pública Federal, tienen entre sus responsabilidades establecer mecanismos internos de supervisión, autoevaluación y remediación, así como recopilar y compartir la información relacionada con incidentes de seguridad, la Agencia de Transformación Digital y Telecomunicaciones, por conducto de la Dirección General de Ciberseguridad, emite las siguientes recomendaciones con la finalidad de fomentar las buenas prácticas que mejoren la ciberseguridad y prevenir la ocurrencia de este tipo de incidentes, conforme a lo siguiente:

Nivel código

- **Validación de control de acceso (ACL)**
Evitar lógica donde únicamente se valida la sesión activa: Debe verificarse explícitamente que el usuario esté autorizado sobre el recurso solicitado.
- **Uso de referencias indirectas a objetos**
Evitar identificadores secuenciales o predecibles (ej. `ID=67124`): El uso de identificadores aleatorios o UUID no sustituye la autorización, sin embargo reduce la enumeración directa.
- **Validación y sanitización de entradas**
Todos los parámetros recibidos vía GET/POST deben validarse estrictamente en tipo, formato y longitud, evitando que valores manipulados generen accesos indebidos.



Nivel infraestructura y operación

➤ Rate limiting y throttling

Limitar el número de solicitudes permitidas hacia endpoints sensibles para reducir intentos de acceso masivo a recursos.

➤ Monitoreo de logs y correlación de eventos (SIEM)

Establecer alertas ante comportamientos anómalos, por ejemplo:

- ★ Un usuario accediendo a múltiples recursos distintos en un corto periodo.
- ★ Cambios repetitivos de identificadores en solicitudes.
- ★ Accesos que no corresponden al patrón normal de uso del sistema.

Gestión de exposición y sistemas legados

- Identificar aplicaciones, APIs o servicios heredados expuestos a Internet y retirar, deshabilitar o aislar aquellos que no sean estrictamente necesarios para operación externa.
- Cuando su uso sea exclusivamente interno o para servicios específicos, restringir su acceso mediante segmentación de red, listas de control de acceso (ACL), VPN o allowlists, evitando su exposición pública.
- Priorizar el cierre de versiones antiguas de APIs o endpoints que no cuenten con controles modernos de autenticación y autorización.

Requerimiento de información y acciones obligatorias

Considerando que **IDOR / Broken Access Control** se encuentra clasificada por OWASP como una de las vulnerabilidades de mayor criticidad y prevalencia, se requiere a los titulares de las dependencias y/o entidades de la Administración Pública Federal en términos de la Política General de Ciberseguridad para la Administración Pública Federal, para que giren sus apreciables instrucciones a quien corresponda, a efecto de que se remita a esta Dirección General, por conducto del Responsable Institucional de Ciberseguridad, la información de las acciones implementadas, así como la evidencia técnica y documental que lo acredite, de conformidad a la tabla siguiente:

#	Requerimiento institucional	OWASP Top 10 (vigente)	Evidencia esperada
1	Revisar y corregir los mecanismos de control de acceso a nivel de objeto en todos los sistemas, aplicaciones y APIs bajo responsabilidad institucional.	A01: Broken Access Control	Documento de análisis de controles de acceso por sistema; diagrama o descripción de autorización a nivel de objeto.



2	Priorizar la revisión de servicios expuestos a Internet, sistemas con datos personales, accesos administrativos y servicios heredados.	A01: Broken Access Control	Inventario de sistemas evaluados; listado de URLs públicas; clasificación de criticidad.
3	Garantizar que cada solicitud valide explícitamente la autorización del usuario sobre el recurso solicitado, independientemente del identificador recibido.	A01: Broken Access Control	Evidencia de validación de pertenencia (ownership check); fragmentos de lógica de autorización o pseudocódigo.
4	Implementar validaciones de autorización independientes de la autenticación, aplicadas obligatoriamente en el backend.	A01: Broken Access Control	Descripción del modelo de autorización (roles, permisos, ACL); evidencia de que no depende solo de sesión activa.
5	Aplicar controles de autorización uniformes y consistentes en todos los endpoints, métodos HTTP y versiones de API.	A01: Broken Access Control	Matriz de endpoints vs controles; pruebas comparativas entre versiones de API.
6	Ejecutar pruebas de acceso no autorizado mediante la manipulación de identificadores de recursos y verificar denegación consistente (401/403).	A01: Broken Access Control	Evidencia de pruebas (capturas, reportes de herramientas); registros de respuestas 401/403.
7	Evitar la exposición de referencias directas a objetos sin validación de autorización.	A01: Broken Access Control	Revisión de parámetros sensibles; evidencia de controles de acceso previos a la resolución del objeto.
8	Implementar controles de autorización centralizados y reutilizables.	A01: Broken Access Control	Arquitectura de control de acceso; uso de middleware, filtros o servicios comunes.
9	Retirar, deshabilitar o aislar servicios que no requieran exposición pública.	A01: Broken Access Control	Evidencia de deshabilitación; reglas de red, ACL, VPN, allowlists.
10	Aplicar controles de autorización en operaciones de consulta, modificación, descarga y eliminación de recursos.	A01: Broken Access Control	Pruebas por operación (CRUD); bitácoras de acceso autorizado/denegado.
11	Monitorear accesos anómalos y patrones de enumeración de objetos.	A01: Broken Access Control	Configuración de logs; reglas SIEM; alertas por acceso indebido.



12	Gestionar la rotación o restablecimiento de credenciales, tokens o llaves asociadas a los sistemas evaluados, cuando aplique.	A01 (impacto transversal)	Evidencia de rotación, políticas de credenciales; bitácoras de cambios.
----	---	---------------------------	---

Plazo de cumplimiento

A efecto de dar cumplimiento al requerimiento antes señalado, **se otorga un plazo máximo de 30 días hábiles**, contados a partir de su notificación.

Dentro del plazo señalado, deberá remitirse:

- **Checklist de cumplimiento por sistema, aplicación o API.**

Finalmente, se hace de conocimiento que, la Agencia de Transformación Digital y Telecomunicaciones, podrá requerir información adicional relacionada con la tabla antes señalada, así como la que resulte necesaria para la gestión de riesgos, vulnerabilidades y cualquier otro elemento relevante.

Se emite el presente con fundamento en los artículos 1, 3, inciso A, fracción III, numeral 1 y 19, fracciones VI y X, así como la Política General de Ciberseguridad para la Administración Pública Federal.